

IR Triage Report

Front Matter

ANALYST NAME: Preston Collins
DATE: 4/30/2026
SOURCE: ModSecurity
ALERT ID: ZgUGhV1CEwAABx43AYAAAAAB
SEVERITY: HIGH
DISPOSITION: True Positive (TP)

Initial Findings

This alert identified a brute-force authentication attack which targeted the WordPress login portal (wp-login.php) on the webserver. The investigation confirmed a coordinated, multi-phase attack: an internal system performed unauthorized WordPress user account creation, then followed by an attacker performing automated credential stuffing using the Hydra tool, which resulted in a successful compromise of both a regular user account and an administrative account. Post-Authentication access to the WordPress admin account was also confirmed.

The activity impacted a single WordPress server, but the compromise was extensive. Both regular and admin credentials were exposed, and unauthorized accounts were created on the system. Evidence also revealed the suspicious activity from 2 unknown internal IP addresses, hinting either compromised internal systems or an insiders involvement.

This alert is dispositioned as a True Positive with high confidence. PCAP analysis confirmed 5 successful authentication events (HTTP 302 response) with some exposed credentials. The SIEM logs independently confirmed the attacker IP, user-agent signature, the targeted URI, and post-authentication admin activity. The attacker pattern (automated brute force using Hydra tool) matches the threat behavior.

The severity is assessed as HIGH based on the confirmed credential compromise of the administrative account on a production system, evidence of post-authentication exploitation (account creation and admin access), multiple corroborating evidence sources and the coordinated attack nature suggesting an active adversary present in the environment.

Incident Summary

Total Time Range and Duration

Incident activity was between **2025-04-10 15:38:41 UTC** and **2025-04-10 15:48:41 UTC**, lasting approximately **10 minutes**. The brute-force authentication phase alone was exactly **6 minutes and 19 seconds** (15:42:22 to 15:48:41 UTC). Pre-attack activity (account preparation) began approximately 3 minutes before the main attack.

Timeline of Key Events

- 2025-04-10 15:38:41 UTC:** The Pre-attack activity begins. Internal system at 10.20.30.200 initiates WordPress admin panel requests including user account creation and management operations using loopback interface.
- 2025-04-10 15:39:50 UTC:** Two identical WordPress user account creation requests (wp-admin/user-new.php) executed simultaneously from 10.20.30.200. Specific usernames not captured in SIEM logs.

- **2025-04-10 15:41:52 UTC:** Pre-attack account preparation activity from 10.20.30.200 concludes. Twelve total events observed across a 3-minute window.
- **2025-04-10 15:42:22 UTC:** Brute-force attack phase begins. Attacker at 192.168.100.20 initiates automated credential stuffing against wp-login.php using the Hydra tool.
- **2025-04-10 15:42:28 UTC:** Attacker successfully authenticates for the first time with regular user account elliot.
- **2025-04-10 15:42:37 UTC:** Second successful authentication with elliot account.
- **2025-04-10 15:42:47 UTC:** Third successful authentication with elliot account.
- **2025-04-10 15:42:56 UTC:** Fourth successful authentication with elliot account.
- **2025-04-10 15:48:41 UTC:** Attacker successfully authenticates with administrative account admin. This is the final and most critical authentication event, granting full administrative access.
- **2025-04-10 15:48:41 UTC:** Attack phase concludes. Last server response observed.

The Scope

The attacker at 192.168.100.20 successfully compromised the WordPress web server at 192.168.100.2 running WordPress 6.7.2. The targeted endpoint was /wp-login.php. Two accounts were compromised: regular user account (elliot) which was authenticated 4 times and administrative account (admin) which was authenticated 1 time. Post-authentication, the attacker accessed the WordPress admin panel at 10.20.30.12 with GET requests to /wp-admin/. An internal system at 10.20.30.200 performed unauthorized user account creation and management operations on the WordPress server 3 minutes before the brute-force attack officially began. The ownership and compromise status of 10.20.30.200 and 10.20.30.12 remain unknown and will require further investigation.

The Impact

The attacker successfully compromised both regular and administrative credentials on the WordPress server. Five successful authentication events were confirmed across the PCAP evidence. Two unauthorized user accounts were created on the system prior to the main attack, potentially establishing persistence. The attacker accessed the WordPress administrative panel post-authentication, gaining the ability to modify site content, install plugins, access configuration files, and potentially access database credentials stored in plaintext. No confirmed service disruption or data exfiltration was observed during the attack window. However, the level of access obtained (admin privileges) means the attacker had full capability to perform destructive actions.

MITRE ATT&CK TTPs

- **T1110.001 – Brute Force: Password Guessing:** Automated POST requests to /wp-login.php using Hydra tool with username/password combinations targeting elliot and admin accounts.
- **T1078 – Valid Accounts:** Successful use of compromised credentials (elliot, admin) to gain authenticated access to WordPress server.
- **T1098 – Account Manipulation:** Creation of unauthorized user accounts via wp-admin/user-new.php prior to main attack phase, likely used for persistence.
- **T1190 – Exploit Public-Facing Application:** Targeted exploitation of publicly accessible WordPress login portal.
- **T1071.001 – Application Layer Protocol: Web Protocols:** All attack activity conducted over HTTP (port 80).

Threat Intelligence Indicators

-Attacker IP: 192.168.100.20

-Suspicious Internal IPs: 10.20.30.200, 10.20.30.12

-Tool Signature: Mozilla/5.0 (Hydra) user-agent string

-Targeted Endpoint: /wp-login.php on WordPress/6.7.2

-Compromised Credentials: elliot / c5G)l#780jlyG!um3y5YRVf5 and admin / Triple10.

-Attack Pattern: Coordinated multi-phase attack with pre-staging account creation followed by automated brute-force credential stuffing. Pattern suggests planning, prior reconnaissance, or insider involvement.

Recommended Actions

IR-related Actions for Impacted Infrastructure

Immediately restrict network access to WordPress server at 192.168.100.2 to prevent further lateral movement or data exfiltration. Force password reset for all WordPress accounts, prioritizing the admin and elliot accounts. Audit and disable the two unauthorized user accounts created at 15:39:50 UTC. Capture forensic disk image and memory dump of the WordPress server before any remediation. Investigate ownership and compromise status of internal systems 10.20.30.200 and 10.20.30.12. Audit WordPress installation for unauthorized files, backdoors, web shells, or modified plugins.

Prevention-related Actions for Impacted Infrastructure

Implement login rate limiting on wp-login.php (maximum 5 failed attempts per IP per 15 minutes with temporary logout). Enforce two-factor authentication for all WordPress administrative accounts. Restrict access to /wp-login.php and /wp-admin/ via IP whitelisting or WAF rules. Disable xmlrpc.php if not required for business operations. Verify WordPress 6.7.2 is fully patched with all available security updates. Audit all installed plugins for hardcoded credentials and or known vulnerabilities.

Prevention-related Actions for Internal Policies

Review and enforce network segmentation between the 192.168.100.0/24 production network and the 10.20.30.0/24 network. Establish formal change control process requiring authorization and logging for all WordPress account creation. Review and enforce least privilege access for all WordPress user accounts. Document all incident response c5G)l#780jlyG!um3y5YRVf5 procedures for identifying and remediating the compromised internal systems.

Detection-related Actions for Improved SOC Flows

Enhance ModSecurity brute-force detection rules to correlate failed login attempts with subsequent successful logins from the same source IP within a 15-minute window. Create a detection rule for WordPress user account creation events (POST to user-new.php) and alert on multiple creation attempts from a single source in a short timeframe. Implement alerting on logins using known security tool user-agent signatures (Hydra, Nikto, etc.). Add post-authentication monitoring for any suspicious administrative API calls (admin-ajax.php, /wp-admin/ endpoints) from unknown sources. Update WordPress incident response playbook to include account creation audit, credential reset procedures, and lateral movement assessment steps.